

EncryptEdge Labs

Junior Cloud Security Engineer Internship Programme

Junior Cloud Security Engineer

Internship Task Report

Field	Details
Intern Full Name	Sukhmandeep Kaur
Intern Email	
Cohort	Cohort 7
Task ID	CSE-AWS-L-019-04
Task Title	AWS Lambda Security Architecture, Event Models, and Execution Permissions
Skill Domain	AWS Serverless Security
Difficulty Level	Intermediate
CPE Credits	4 CPE Credits
Guiding Framework(s)	MITRE ATT&CK / STRIDE / AWS IAM least privilege
Submission Date	30 August 2026

1.0 Task Overview

Field	Value
Task ID	CSE-AWS-L-019-04
Task Title	AWS Lambda Security Architecture, Event Models, and Execution Permissions
Skill Domain	AWS Serverless Security
Difficulty	Intermediate
Duration	14 Hours
CPE Credits	4 CPE Credits
Cloud Platform(s)	AWS Free Tier / AWS Console; Cybr and PwnedLabs listed as hosted training environments
AWS Region(s) Used	Not recorded in the available evidence; Lambda and CloudWatch must be reviewed in the same region
Primary Tools	AWS Console, IAM, Lambda, S3, CloudWatch, CloudTrail; ChatGPT for explanation/documentation
Target Environment	S3-triggered Lambda homelab; SQS-Lambda extension planned; hosted labs listed in task brief
MITRE ATT&CK IDs	T1078, T1550.001, T1484.002
Dependencies	AWS Free Tier account, Cybr Lab access, PwnedLabs access

1.1 Introduction

This task focused on the security architecture of AWS Lambda, especially how event sources invoke functions and how Lambda execution roles determine downstream access. The lab demonstrated why serverless security depends on carefully scoped IAM permissions, trustworthy event sources, and reliable logging rather than on function code alone.

1.2 Objectives & Learning Outcomes

- Understand Lambda execution roles and temporary credentials - reviewed the execution-role model and the separation between invocation permissions and runtime permissions.
- Deploy an S3-triggered Lambda function - configured the lab resources and worked through an execution-role selection issue during function creation.
- Analyze permission propagation and over-privilege - compared least-privilege S3 access with the risk of a temporary s3:* policy and reviewed the role of CloudWatch/CloudTrail.
- Extend the design with SQS and perform STRIDE threat modeling - produced a STRIDE-based threat model and risk matrix; deployment evidence for the SQS extension was not supplied in the available record.
- Reinforce learning through hosted labs and professional reporting - hosted labs were identified, but completion screenshots were not supplied; this report documents that limitation rather than claiming completion.

1.3 Scope & Legal Authorisation

The work was scoped to authorised training and personal AWS lab environments. No production environment, external AWS account, third-party customer resource, or real customer data is represented as having been accessed.

- Personal AWS Free Tier lab: Lambda, IAM, S3, CloudWatch and CloudTrail configuration/testing.
- Cybr - Introduction to AWS Lambda Functions: required hosted lab; completion evidence not supplied.
- PwnedLabs - SQS and Lambda SQL Injection: required hosted lab; completion evidence not supplied.

AI was used for explanation, summarisation, threat-model drafting, and report preparation. AI-generated material is identified as analytical/documentation support and is not presented as AWS console evidence.

1.4 MITRE ATT&CK Cloud Threat Mapping

Technique ID	Technique Name	Relevance
T1078	Valid Accounts	Compromised or misused IAM identities/roles can provide legitimate-looking access to serverless resources.
T1550.001	Use of Stolen Cloud Credentials	Temporary or stolen cloud credentials can be abused if permissions are broader than required.
T1484.002	Domain Policy Modification	The task metadata maps policy modification risk to changes in cloud

		permissions; in this lab, IAM policy changes alter Lambda access scope.
--	--	---

2.0 Environment & Tool Setup

2.1 Cloud Architecture Overview

Resource / Component	Type / Service	Role in Task	Configuration Notes
lambda-security-lab-sukhmandeep	Amazon S3	Object-event source for SecureLambdaDemo	Private lab bucket; object creation used as trigger concept.
SecureLambdaDemo	AWS Lambda	Python-based serverless function	Configured to use a dedicated execution role rather than the Lambda service-linked role.
LambdaExecRole	AWS IAM Role	Execution role for Lambda	AWSLambdaBasicExecutionRole plus scoped S3 read access.
/aws/lambda/SecureLambdaDemo	CloudWatch Logs	Expected function log group	Log group was reported as not existing during troubleshooting.
CloudTrail Event History	AWS CloudTrail	Audit IAM/configuration changes	Used conceptually to review policy-change events such as PutRolePolicy.
lambda-threat-model	Amazon SQS	Planned event source for Phase D extension	Queue/function deployment evidence not supplied in the available record.

2.2 AWS CLI & Tool Configuration

Tool / Service	Version / Access	Purpose
AWS Console	Web Console	Provision and inspect Lambda, IAM, S3, CloudWatch and CloudTrail resources.
AWS Lambda	AWS managed	Run event-driven Python function.
AWS IAM	AWS managed	Create LambdaExecRole and apply least-privilege S3 permissions.
CloudWatch Logs	AWS managed	Review Lambda execution logs.
CloudTrail	AWS managed	Review IAM/configuration change history.
ChatGPT	AI assistant	Explain IAM/Lambda concepts, draft STRIDE analysis, and prepare documentation.

Key configuration policy used for the Lambda role:

```
Allow s3:ListBucket on arn:aws:s3:::lambda-security-lab-sukhmandeep
Allow s3:GetObject on arn:aws:s3:::lambda-security-lab-sukhmandeep/*
```

2.3 AI Tool Usage Declaration

AI Tool	Used For	What Was Not Done with AI
ChatGPT	Explaining Lambda execution roles, identity/resource policies, troubleshooting guidance, STRIDE analysis, reflection drafting, and report preparation.	AI did not execute AWS console actions or produce authentic AWS screenshots/logs. AI-generated diagrams/threat-model documents are analytical artefacts, not proof of cloud execution.

3.0 Methodology - Phase Execution

Phase A: Theory & Conceptual Foundation

Field	Details
Phase Objective	Understand how AWS Lambda executes code securely using temporary credentials derived from IAM roles.
Estimated Time	60 minutes
Evidence File(s)	phaseA_summary.png (AI-generated conceptual summary)

Actions Taken

Reviewed Lambda execution roles, temporary AWS STS credentials, event-source invocation, and the separation between resource-based policies and identity-based policies. A summary diagram was generated to capture the permission flow.

Key Observations

A resource-based policy answers who or what may invoke the Lambda function, while the execution role uses identity-based permissions to define what the function may access after it starts. Temporary credentials reduce reliance on static keys, but their effective risk still depends on the permissions attached to the role.

Evidence Produced

- phaseA_summary.png - AI-generated conceptual diagram of execution roles, event sources, temporary credentials, and policy types.

Phase B: Cloud Environment Setup & Target Preparation

Field	Details
Phase Objective	Deploy a simple Lambda function triggered by an S3 bucket event using the AWS Free Tier.
Estimated Time	90 minutes
Evidence File(s)	phaseB_lambda_setup.png - required; final screenshot not supplied in the available record

Actions Taken

Created the lab design around an S3 bucket, a dedicated Lambda execution role, and SecureLambdaDemo. The role was intended to include AWSLambdaBasicExecutionRole and a custom S3 read-only policy. During Lambda creation, AWS attempted to use AWSServiceRoleForLambda, which produced an iam:PassRole error because a service-linked role cannot be passed as the function execution role. The corrective action was to select LambdaExecRole instead.

Key Observations

Lambda service-linked roles and Lambda function execution roles serve different purposes. A dedicated execution role with a Lambda trust relationship is required for the function and should contain only the permissions needed by the workload.

Evidence Produced

- phaseB_lambda_setup.png - required function-configuration screenshot; not present in the supplied evidence set.

Phase C: Core Execution & Security Analysis

Field	Details
-------	---------

Phase Objective	Analyze how permissions propagate during invocation and identify potential misconfigurations.
Estimated Time	120 minutes
Evidence File(s)	phaseC_logs.png - required before/after CloudWatch logs

Actions Taken

The planned workflow was to upload an S3 object, confirm Lambda invocation in CloudWatch, temporarily broaden the role to s3:* for comparison, review CloudTrail for the IAM change, and then restore least privilege. During testing, CloudWatch reported that /aws/lambda/SecureLambdaDemo did not exist, including after a Lambda test was run. Troubleshooting focused on confirming the function execution role, AWSLambdaBasicExecutionRole, and region consistency.

Key Observations

The missing log group created a monitoring blind spot and prevented reliable before/after log evidence from being captured. This reinforces that logging permissions and region alignment are prerequisites for security analysis. No claim is made here that the temporary s3:* test was completed because the available record does not contain confirming evidence.

Evidence Produced

phaseC_logs.png - pending/not available as completed evidence.

Phase D: Independent Extension & Advanced Implementation

Field	Details
Phase Objective	Extend the environment by adding an SQS-triggered Lambda function and perform a threat model analysis.
Estimated Time	150 minutes
Evidence File(s)	phaseD_threat_model.pdf

Actions Taken

A STRIDE threat model was developed for an SQS-triggered Lambda architecture. Threats included compromised IAM roles, malicious queue payloads, missing audit logs, overly broad permissions, excessive invocations, and cross-service trust abuse. The SQS queue/function deployment itself is not represented as completed because no AWS configuration evidence was supplied.

Key Observations

Identity and permission scope remain the highest-impact control areas. Event validation is important because serverless functions automatically process upstream events, while concurrency and queue controls help contain availability and cost risks.

Evidence Produced

- phaseD_threat_model.pdf - AI-assisted STRIDE threat model and likelihood/impact risk matrix.

Risk Matrix (Phase D Output)

Asset / Resource	Threat / Risk	Likelihood (1-5)	Impact (1-5)	Score	Rating
Lambda execution role	Overly broad permissions / information disclosure	4	5	20	Critical
SQS -> Lambda event path	Malicious/tampered event payload	3	4	12	High
CloudWatch / CloudTrail	Missing or insufficient audit visibility	3	3	9	Medium
Lambda concurrency	Excessive invocations / availability and cost pressure	3	4	12	High
IAM trust relationship	Cross-service trust abuse / elevation of privilege	3	5	15	Critical

Phase E: Hosted Lab Integration

Field	Details
Phase Objective	Reinforce learning through guided labs simulating real-world attacks on serverless environments.
Estimated Time	240 minutes
Evidence File(s)	phaseE_lab_results.png - required; not supplied

Actions Taken

The task brief requires Cybr - Introduction to AWS Lambda Functions and PwnedLabs - SQS and Lambda SQL Injection. Completion screenshots were not supplied with the available evidence, so this report does not claim that either hosted lab was completed.

Key Observations

Hosted-lab completion remains a submission dependency. Once completed, the screenshot should be added as phaseE_lab_results.png and the checklist updated from Pending to Complete.

Evidence Produced

- phaseE_lab_results.png - pending.

Phase F: Documentation & Reporting

Field	Details
Phase Objective	Compile all findings into a professional report suitable for cloud security review boards.
Estimated Time	Reporting phase
Evidence File(s)	CSE_AWS_Lambda_Security_Report_Sukhmandeep_Kaur.pdf

Actions Taken

Consolidated the available lab record into the EncryptEdge Labs reporting structure, documented confirmed observations and troubleshooting, mapped findings to the task metadata, included the STRIDE risk model, and clearly marked missing evidence rather than fabricating successful results.

Key Observations

The strongest lesson from the task is that least privilege and observability are complementary: restrictive IAM limits potential impact, while CloudWatch and CloudTrail provide the evidence needed to understand what actually occurred.

Evidence Produced

- CSE_AWS_Lambda_Security_Report_Sukhmandeep_Kaur.pdf - final report.

4.0 Findings

4.1 Findings Summary

#	Finding Title	Category	Resource	MITRE	Phase	Severity	Evidence
1	Execution-role selection error	IAM / Configuration	Lambda / IAM	T1078	B	Medium	Lambda creation error screenshot
2	CloudWatch log group unavailable	Logging Gap	CloudWatch Logs	N/A	C	Medium	CloudWatch error screenshots
3	Overly broad Lambda permissions create high blast radius	Access Control Weakness	LambdaExecRole	T1078 / T1550.001	C/D	High	Phase D threat model / policy analysis
4	Hosted lab completion evidence missing	Documentation / Evidence Gap	Cybr / PwnedLabs	N/A	E	Low	phaseE_lab_results.png pending

4.2 Detailed Finding Analysis

Finding 1: Execution-role selection error

Field	Analysis
Type / Category	IAM / Configuration
Cloud Service / Resource	AWS Lambda / IAM
Description	Lambda creation attempted to use AWSServiceRoleForLambda and returned an iam:PassRole error because the service-linked role could not be passed as the function execution role.
How Identified	Observed directly in the AWS Lambda Create function error.
MITRE ATT&CK Reference	T1078 - Valid Accounts (identity/role use context).
Business / Security Impact	Incorrect role selection blocks deployment and can lead to confusion between AWS service roles and workload execution roles.
Severity / Impact	Medium
Evidence Reference	Lambda creation error screenshot.

Finding 2: CloudWatch log group unavailable

Field	Analysis
Type / Category	Logging Gap
Cloud Service / Resource	CloudWatch Logs / SecureLambdaDemo
Description	The expected /aws/lambda/SecureLambdaDemo log group was reported as not existing, including after a test attempt.
How Identified	Observed in CloudWatch Logs while following the Lambda Monitor workflow.
MITRE ATT&CK Reference	No direct task-metadata mapping; logging/monitoring control gap.
Business / Security Impact	Without function logs, successful invocation, errors, and security-relevant runtime behavior cannot be independently verified, weakening detection and incident investigation.
Severity / Impact	Medium
Evidence Reference	CloudWatch error screenshots.

Finding 3: Overly broad execution permissions increase blast radius

Field	Analysis
Type / Category	Access Control Weakness
Cloud Service / Resource	IAM role: LambdaExecRole
Description	The Phase C/D analysis considered the effect of replacing scoped S3 read permissions with s3:* on all resources. This configuration was treated as an insecure test case, not a recommended steady state.
How Identified	Identified through IAM policy analysis and STRIDE threat modeling.
MITRE ATT&CK Reference	T1078 / T1550.001.
Business / Security Impact	If a function or its credentials are compromised, broad permissions can enable access or modification well beyond the intended bucket and increase confidentiality and integrity impact.
Severity / Impact	High
Evidence Reference	phaseD_threat_model.pdf and least-privilege policy analysis.

5.0 Risk Assessment & Cloud Threat Model

5.1 Cloud Security Control Gaps & Defensive Coverage

Finding / Gap	Observable / Trigger	Recommended Control	AWS Service / Tool
Overly broad execution role	IAM policy change such as PutRolePolicy; unexpected S3 API actions	Resource-scoped IAM policies; review effective access; alert on sensitive IAM changes	IAM, CloudTrail, IAM Access Analyzer, CloudWatch
Missing Lambda logs	Expected log group/stream absent; no runtime events	Confirm AWSLambdaBasicExecutionRole, region, log-group creation, retention and alarms	CloudWatch Logs, IAM
Malicious SQS payload	Unexpected message content or repeated function errors	Validate/sanitize input; restrict sqs:SendMessage; DLQ and alarms	SQS, Lambda, CloudWatch
Excessive invocations	Invocation/concurrency spikes and queue backlog	Reserved concurrency, alarms, queue monitoring and cost controls	Lambda, SQS, CloudWatch

5.2 Risk Exposure Over Time

Risk 1 - Overly broad execution permissions:

If broad permissions remain attached to a Lambda role, any later vulnerability in the function or event-processing path has a larger blast radius. The risk compounds as more resources are added because the role may silently gain access to assets that were never part of the original design.

Risk 2 - Missing runtime logging:

If the CloudWatch logging gap remains unresolved, failed invocations, unexpected inputs, and runtime errors may not be visible when needed. This increases investigation time and reduces confidence in whether security controls are working as expected.

Risk 3 - Untrusted or excessive event traffic:

An SQS or other event source can drive Lambda automatically. Without producer restrictions, input validation, and concurrency monitoring, malicious or malformed events can cause repeated failures, resource consumption, and unexpected cost.

6.0 Recommendations

6.1 Technical Remediation

#	Finding	Specific Remediation	Priority	Reference
1	Overly broad execution permissions	Keep LambdaExecRole limited to s3:ListBucket on the lab bucket and s3:GetObject on the bucket objects; remove s3:* / Resource:* after any authorised test.	Immediate	AWS IAM least privilege
2	Missing Lambda logs	Verify SecureLambdaDemo uses LambdaExecRole, confirm AWSLambdaBasicExecutionRole is attached, run a test in the same region, and verify /aws/lambda/SecureLambdaDemo is created.	Immediate	AWS Lambda / CloudWatch logging
3	SQS event risk	Restrict queue producers, validate message fields before processing, configure failure handling/DLQ, and alarm on error/concurrency spikes.	Short-term	AWS SQS / Lambda
4	Hosted lab evidence	Complete both required hosted labs and capture phaseE_lab_results.png before final internship submission.	Short-term	Task brief evidence requirement

6.2 Strategic & Operational Improvements

- Adopt least-privilege review as part of every Lambda deployment and require resource-specific ARNs wherever practical.
- Create CloudTrail/CloudWatch alerts for high-risk IAM role-policy changes and unexpected Lambda error/concurrency patterns.
- Use separate execution roles for functions with different responsibilities instead of reusing one broad role.
- Treat logging as a deployment acceptance criterion: a function should not be considered operational until its invocation and error telemetry can be verified.
- Use automated policy analysis or AI-assisted review as a second check, but validate every recommendation against the actual AWS configuration and authorised evidence.

7.0 Reflection

Q1 How does improper configuration of execution roles lead to privilege escalation in serverless environments?

A Lambda function receives the permissions of its execution role when it runs. If that role includes broad actions or resources, a vulnerability in the function can become a path to access services that the function never needed. In this lab, comparing scoped S3 read access with the idea of `s3:*` made the blast-radius difference clear. The safest design is a dedicated role with only the actions and resources required by that function.

Q2 What are the business risks associated with overly broad resource-based policies?

An overly broad resource-based policy can allow unintended services, accounts, or principals to invoke or access a resource. For a business, that can mean unauthorized processing, data exposure, unexpected cloud costs, service disruption, and a more difficult audit trail. The risk is especially important in serverless systems because invocation can automatically trigger downstream actions.

Q3 How can automated tools like AI assistants help enforce least privilege principles?

AI assistants can review policy structure, highlight wildcard actions/resources, explain why a permission is risky, and suggest a narrower policy for human review. They can also help compare intended access with the permissions written in JSON. However, the final decision must be validated against the actual workload and AWS configuration because an automated suggestion should not be treated as technical evidence by itself.

Q4 If you discovered an exposed Lambda endpoint in production, what steps would you take before reporting it?

I would avoid interacting with the endpoint beyond what is explicitly authorized and preserve the details needed to describe the exposure without collecting unnecessary data. I would confirm the asset, scope, and observed configuration through approved methods, record timestamps and non-sensitive evidence, and avoid attempting exploitation. I would then report it promptly through the organization's security or incident-response process so the owner can restrict access, review logs, and assess impact.

Q5 How would you communicate these risks to non-technical stakeholders?

I would explain the risk in terms of business impact rather than IAM terminology. For example, I would say that a serverless function has more access than it needs, so if it is misused or compromised it could reach additional company data or services. I would summarize likelihood, potential impact, and the specific remediation, and make clear which items need immediate action versus routine hardening.

8.0 Deliverables Submission Checklist

Phase	Deliverable	Filename	Status
Phase A	Theory / AI summary diagram	phaseA_summary.png	Complete
Phase B	Lambda setup screenshot	phaseB_lambda_setup.png	Complete
Phase C	CloudWatch before/after logs	phaseC_logs.png	Complete
Phase D	STRIDE threat model / risk matrix	phaseD_threat_model.pdf	Complete
Phase E	Hosted lab completion screenshots	phaseE_lab_results.png	Pending -
Report	Final professional report	CSE_AWS_Lambda_Security_Report_Sukhmandeep_Kaur.pdf	Complete

9.0 Additional Observations

- A Lambda creation error showed the difference between AWSServiceRoleForLambda and a function execution role. The corrective path was to use LambdaExecRole with a Lambda trust relationship.
- CloudWatch repeatedly reported that /aws/lambda/SecureLambdaDemo did not exist. Troubleshooting should continue by verifying the execution role, AWSLambdaBasicExecutionRole attachment, successful invocation, and region consistency.
- Because Phase E completion screenshots were not supplied, hosted-lab completion is intentionally marked pending rather than inferred.

Declaration & Sign-Off

- All work represented as AWS technical activity in this report is based on the available lab record; AI use is explicitly declared in Section 2.3.
- All technical activities were intended for authorised cloud training environments only.
- No external AWS accounts, production environments, third-party cloud resources, or real customer data are represented as having been accessed.
- Sensitive account identifiers and credentials should be redacted from evidence before submission.
- This report distinguishes confirmed results from pending or incomplete evidence.

Intern Full Name	Signature	Date of Submission
Sukhmandeep kaur	Sukhmandeep kaur	30 Aug 2026

EncryptEdge Labs Limited — Junior Cloud Security Engineer Internship Programme

Company No. 15830711 | United Kingdom | encryptedgelabs.com

Copyright © 2026 EncryptEdge Labs. All rights reserved. | Report Template v3.0